

Java Exploitation Restrictions in Modern JDK Times

Java Exploitation Restrictions in Modern JDK Times - Author not stated, codewhitesec.blogspot.com.

- Published: date not stated
- Original: <<https://codewhitesec.blogspot.com/2023/04/java-exploitation-restrictions-in.html>>
- Preserved from: <https://codewhitesec.blogspot.com/2023/04/java-exploitation-restrictions-in.html> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Java deserialization gadgets have a long history in context of vulnerability research and at least go back to the year 2015. One of the most popular tools providing a large set of different gadgets is [ysoserial](#) by Chris Frohoff. Recently, we observed increasing concerns from the community why several gadgets do not seem to work anymore with more recent versions of JDKs. In this blog post we try to summarize certain facts to reenale some capabilities which seemed to be broken. But our journey did not begin with deserialization in the first place but rather looking for alternative ways of executing Java code in recent JDK versions. In this blost post, we'll focus on OpenJDK and Oracle implementations. Defenders should therefore adjust their search patterns to these alternative code execution patterns accordingly.

ScriptEngineManager - It's Gone

Initially, our problems began on another exploitation track not related to deserialization. Often code execution payloads in Java end with a final call to `java.lang.Runtime.getRuntime().exec(args)`, at least in a proof-of-concept exploitation phase. But as a Red Team, we always try to maintain a low profile and avoid actions that may raise suspicion like spawning new (child) processes. This is a well-known and still hot topic discussed in the context of C2 frameworks today, especially when it comes to AV/EDR evasion techniques. But this can also be applied to Java exploitation. It is a well-known fact that an attacker has the choice between different approaches to stay within the JVM to execute arbitrary Java code, with `new javax.script.ScriptEngineManager().getEngineByName(engineName).eval(scriptCode)` probably being the most popular one over the last years. The input code used is usually based on *JavaScript* being executed by the referenced ScriptEngine available, e.g. *Nashorn* (or *Rhino*).

But since Nashorn was marked as deprecated in Java 11 ([JEP 335](#)), and removed entirely in Java 15 ([JEP 372](#)), this means that a target using a *JDK version* ≥ 15 won't process JavaScript payloads anymore by default. Instead of hoping for other manually added JavaScript engines by developers for a specific target, we could make use of a "new" Java code evaluation API: *JShell, a read-eval-print loop (REPL) tool that was introduced with Java 9* ([JEP 222](#)). Mainly used in combination with a *command line interface (CLI)* for testing Java code snippets, it allows programmatic access as well (see [JShell API](#)). This new evaluation call reads like `jdk.jshell.JShell.create().eval(javaCode)`, executing *Java code snippets* (not JavaScript!). Further call variants exist, too. We found this being mentioned already in [2019 used in context of a SpEL Injection](#) payload. This all sounded too good to be true but nevertheless [some restrictions](#) seemed to apply.

"The input should be exactly one complete snippet of source code, that is, one expression, statement, variable declaration, method declaration, class declaration, or import."

So, we started to play with some Java code snippets using the JShell API. First, we realized that it is indeed possible to use `import` statements within such snippets but interestingly the subsequent statements were not executed anymore. This should have been expected by reading the quote above, i.e. one would have actually been restricted to a single statement per snippet.

We also learned that it makes a huge difference between using the CLI vs. the API programmatically. The `jshell` CLI tool supports the listing of pre-imported packages:

I.e. a code snippet in the CLI executing `Files.createFile(java.nio.file.Paths.get("/tmp/RCE"));` works just fine. Calling the `eval` method programmatically on a `JShell` instance instead gives a different result, namely `Files` not known in this context. As a side note, `eval` calls do not return any exception messages printed to `stdout/stderr`. For "debugging" purposes, the `diagnostics` methods helps a lot: `jshell.diagnostics(events.get(0).snippet()).forEach(x -> System.out.println(x.getMessage(Locale.ENGLISH)));`.

Thus, it seems that we don't have access to a lot of "useful" classes with the programmatic approach. But as you already might have guessed, using fully qualified class names can be used as well. We don't have to "fix" the `import` issue mentioned above but can still use all built-in JDK classes by referencing them accordingly: `java.nio.file.Files.createFile(java.nio.file.Paths.get("/tmp/RCE"));`. This gives us again all the power needed to build (almost) arbitrary Java code payloads for exfiltrating data, putting them in a server response etc. pp.

Ysoserial - The Possible

Besides the fact, that we could now benefit from this approach to inject these kinds of payloads in various attacking scenarios, this blog post should also be about insecure deserialization exploitation. Starting with a well-known gadget `CommonsCollections6`, the original `Runtime.getRuntime().exec(args)` will be replaced with a `JShell` variant. Using the handy `TransformerChain` pattern, one simply has to replace the chain accordingly.

After a small adjustment to the `pom.xml`

we're ready to rebuild the ysoserial package with `maven`. But creating a payload with a recent version of JDK (*version 17* in our case) revealed the following error.

In *JDK9*, the *Java Platform Module System (JPMS)* was introduced based on the "historical" project Jigsaw. We highly recommend the reader to look through the historical timeline with the corresponding JEPs in [this IBM Java tutorial](#). E.g. [JEP 260](#) describes the fact that most internal JDK APIs should be encapsulated properly such that Getters and Setters have to be used for access/change of otherwise privately declared internal member variables. Also the new Java module structure should explicitly restrict access between different modules, i.e. declaring lists of exported packages will become a "must" to allow inter-module access via the new module descriptor `module-info.java`. Additionally, since *JDK16* the default strategy with respect to Java Reflection API is set to "deny by default" ([JEP 396](#)).

The `CommonsCollections` library is not implemented as Java module so that by definition it falls in the category **unnamed** (compare with exception message above).

Browsing through the ysoserial GitHub issue tracker, it appears people seem to have similar problems recently. One of the best articles explaining this kind of issue comes [from Oracle itself](#). The chapter "Illegal Reflective Access" nicely summarizes the adjustments to JDK versions with respect to access of otherwise inaccessible members between packages via Java Reflection API.

"Some tools and libraries use reflection to access parts of the JDK that are meant for internal use only. This is called illegal reflective access and by default is not permitted in JDK 16 and later.

... Code that uses reflection to access private fields of exported java.* APIs will no longer work by default. The code will throw an `InaccessibleObjectException`."

Furthermore, Oracle states that

"If you need to use an internal API that has been made inaccessible, then use the `--add-exports` runtime option. You can also use `--add-exports` at compile time to access internal APIs.

If you have to allow code on the class path to do deep reflection to access nonpublic members, then use the `--add-opens` option."

Since `CommonsCollections6` (and most of other gadgets) make heavy use of the Java Reflection API via `java.lang.reflect.Field.setAccessible(boolean flag)`, this restriction has to be taken into account accordingly. Oracle already gave the solution above. Note that the `--add-exports` parameter does not allow "deep reflection", i.e. access to otherwise private members. So, creating the payload using `java --add-opens java.base/java.util=ALL-UNNAMED -jar target/ysoserial-0.0.6-SNAPSHOT-all.jar CommonsCollections6 "java.nio.file.Files.createFile(java.nio.file.Paths.get("/tmp/RCE"));"` works just fine and gives code execution in insecure deserialization sinks again.

Ysoserial - The Impossible

Another popular gadget is `CommonsBeanutils1`, still frequently used in these days to gain code execution through insecure deserialization. A short side note: this gadget chain uses `Gadgets.createTemplatesImpl(cmd)` to put your command into a Java statement, compiled then into bytecode which is executed later. Chris Frohoff already gave a [nice hint in his code](#) that instead of

the `java.lang.Runtime.getRuntime().exec(cmd)` call, one "[...] could also do fun things like injecting a pure-java rev/bind-shell to bypass naive protections". That's already a powerful primitive which might not have been used by too many people over the last years (at least not been made public as popular choice).

But let's get back to trying to create a payload in JDK17 which unfortunately results in a different exception compared to `CommonsCollections6`.

This kind of error is expected, cross-checking with the Oracle article mentioned above, and can therefore be solved with the same approach: `java --add-`

```
opens=java.xml/com.sun.org.apache.xalan.internal.xsltc.trax=ALL-UNNAMED --add-  
opens=java.xml/com.sun.org.apache.xalan.internal.xsltc.runtime=ALL-UNNAMED --add-opens  
java.base/java.util=ALL-UNNAMED -jar target/ysoserial-0.0.6-SNAPSHOT-all.jar CommonsBeanutils1 "[  
JAVA_CODE]" (see also Chris Frohoff's comment on an issue).
```

You might be aware of the deserializer test class in ysoserial. This can be called by piping the payload creation result directly into `java -cp ./target/ysoserial-0.0.6-SNAPSHOT-all.jar ysoserial.Deserializer`. You should first test this with our `CommonsCollections6` case above.

But what if we do this with our successfully created `CommonsBeanutils1` gadget?

Sounds familiar? Unfortunately, this scenario is equivalent to server side deserialization processing, i.e. no code execution! If you add the `--add-opens` parameters to the `ysoserial.Deserializer` as well, deserialization works as expected of course but in a remote attack scenario we obviously don't have control over this!

Since `org.apache.commons.beanutils.PropertyUtilsBean` tries to access `com.sun.org.apache.xalan.internal.xsltc.trax.TemplatesImpl`, traditional paths in gadget chains like `TemplatesImpl` turned out to be useless in most cases. This, again, is because third-party libraries known from ysoserial are not Java modules and the module system strongly protects internal JDK classes. If we check the `module-info.java` in JDKs `java.xml/share/classes/` directory, no exports can be found matching these package names needed. Game over.

Conclusions

- Use `JShell` instead of `ScriptEngineManager` for JDK versions ≥ 15 (side note: this is not available in JREs!). This is also relevant for Defenders searching for code execution patterns only based on `Runtime.getRuntime().exec` or `ScriptEngineManager().getEngineByName(engineName).eval` calls. Keep in mind, this already affects JDK versions ≥ 9 .
- For JDK versions < 16 , use the `--add-opens` property Setters during payload creation.
- For JDK versions ≥ 16 , rely on known (or find new) Java deserialization gadgets which do not depend on access to internal JDK class members etc. However, check for the exported namespaces before giving up a certain gadget chain.